

ÉCOLE NATIONALE D'INGÉNIEURS ABDERHAMANE BABA TOURÉ · BAMAKO

Une défense locale pour les applications PHP.

Détecter et examiner les tentatives d'injection SQL grâce à des règles lisibles et un modèle MLP exécuté localement.

MVP fonctionnel

Inférence locale

Périmètre SQLi

Mode observation

Stade réel du projet

Le dépôt contient un démonstrateur local testable. Aucun pilote client, audit externe, test d'intrusion indépendant ou résultat de latence en charge n'est revendiqué.

PORTEUR INDIQUÉ DANS LE DOSSIER INITIAL

Sékou Doucouré

En collaboration avec Adama Nakoun Fané

Noms, rôles et accord des membres à confirmer avant dépôt.

CANDIDATURE

Concours Innovation

Journées Nationales de la Cybersécurité

Mali · 26–30 octobre 2026

LE BESOIN ET LE PÉRIMÈTRE

Une couche de visibilité, spécialisée et locale.

CyberShield AI est un middleware de défense en profondeur conçu pour une application PHP. Il examine les valeurs de requête avant leur traitement, journalise sa décision et permet de commencer en mode observation.

BESOIN EXPLORÉ

Les responsables d'applications de petite taille peuvent manquer d'outils simples pour repérer et comprendre les tentatives SQLi. Une analyse hébergée localement peut limiter le transfert des entrées vers un tiers. Cette hypothèse de besoin et la volonté de payer restent à confirmer par des entretiens et un pilote.

UTILISATEUR VISÉ

Administrateur ou intégrateur chargé d'une application web PHP, notamment dans une petite organisation qui préfère conserver ses journaux et son traitement sur son infrastructure.

Objectif du MVP

Aider l'exploitant à repérer des entrées candidates à l'injection SQL et à examiner les décisions dans une console locale, sans prétendre remplacer la correction du code vulnérable.

Fonctions effectivement présentes

- Middleware PHP et règles heuristiques SQLi.
- Analyse MLP locale de certaines valeurs ambiguës.
- Décision bloquée, observée ou autorisée selon le mode.
- Journal d'événements structuré et console d'administration.
- Mode observation pour étudier les signaux.
- Limites de taille et de débit.
- MFA administrateur et protections CSRF documentées.
- Laboratoire pédagogique qui n'exécute pas le SQL soumis.

Limite fonctionnelle

Le MVP est spécialisé sur les injections SQL. Les modules XSS, LFI, audit de mots de passe, détection réseau et conformité sont des pistes futures, pas des protections déjà livrées. La boutique est un environnement de démonstration.

Les requêtes préparées, le moindre privilège en base, les mises à jour et les contrôles propres à l'application restent indispensables. CyberShield AI est une couche complémentaire.

COMMENT L'ANALYSE FONCTIONNE

Règles rapides, examen local borné.

Le traitement reste dans l'environnement local du démonstrateur. Les signatures évidentes sont évaluées en PHP. Le MLP Python reçoit un nombre limité de valeurs par requête; il n'est pas appelé comme un service public et sa sortie n'est pas une probabilité calibrée de justesse.

01 · Requête Valeurs HTTP prises en charge et limites d'entrée	02 · Règles Normalisation et scores heuristiques SQLi	03 · MLP local Examen borné des valeurs candidates	04 · Décision Autoriser, observer ou bloquer selon la politique	05 · Journal Événement expurgé dans la console locale
--	---	--	---	---

Le modèle MLP v2 est un classifieur binaire entraîné sur des caractéristiques de chaînes. La version documentée utilise 37 caractéristiques, une architecture 37→128→64→32→1 et un seuil de décision fixe de 0,75. Le score de sortie n'est pas calibré.

Composants du dépôt

Composant	Implémentation présente	Rôle
Filtre et application	PHP 8.4, Apache, mysql	Interception des entrées, règles, contrôle et requêtes préparées dans l'application de démonstration.
Inférence locale	Python 3.13, Flask/Waitress, scikit-learn	MLP chargé depuis un artefact local versionné; service non publié directement sur le port hôte par Compose.
Stockage	MariaDB et journaux JSONL	Données applicatives fictives, événements de sécurité et données d'exploitation.
Déploiement de démonstration	Docker Compose ou Wamp	Installation locale reproductible, sous réserve de valider chaque cible de déploiement.

Données de requête

Les journaux n'enregistrent pas les valeurs brutes des payloads; les valeurs ordinaires sont empreintées et des champs sensibles sont masqués. Les journaux contiennent néanmoins des métadonnées comme l'adresse IP ou le chemin et doivent rester privés. Un envoi SIEM est possible seulement s'il est configuré; il porte sur les événements expurgés.

Le dépôt utilise `mysqli` avec paramètres liés; l'architecture n'est pas Slim/PDO comme l'indiquait le dossier initial. L'explication dans la console est locale et déterministe; aucun assistant LLM n'est inclus dans le MVP actuel.

RÉSULTATS DOCUMENTÉS

Des chiffres lisibles avec leur contexte.

Les évaluations disponibles portent sur des corpus publics. Elles mesurent une séparation de classes dans ces jeux, et non la sécurité d'un service réel.

Source et protocole	Résultat reproductible	Limite à retenir
HttpParamsDataset — test distinct 10 051 valeurs `norm`/`sql`, seuil 0,75 fixé à l'avance; split de la même famille publique que l'entraînement.	F1 0,999170 Précision 0,999723 Rappel 0,998618 TN 6 433 · FP 1 · FN 5 · TP 3 612	Jeu de test séparé, mais mêmes sources/famille de données. Ne prouve pas la généralisation au trafic d'un client.
SR-BH 2020 — MLP seul 775 506 lignes normales ou SQLi d'une capture sur un honeypot WordPress, pendant douze jours.	F1 0,862153 Précision 0,865160 Rappel 0,859167 Spécificité 0,936180	Capture unique, distribution et étiquettes propres à ce honeypot. La spécificité implique environ 6,4 % de faux positifs parmi les lignes normales de cette capture.
SR-BH 2020 — rejeu de la politique hybride Rejeu logiciel des règles et du budget d'analyse MLP du middleware sur la même capture.	F1 0,860560 Précision 0,865092 Rappel 0,856075 Spécificité 0,936372	La politique de présélection a été retenue après examen de cette capture. Mesure de développement, pas confirmation indépendante ni test HTTP en charge.

20 105

valeurs sélectionnées pour l'entraînement

37

caractéristiques du MLP v2

0

pilote réel documenté à ce jour

À ne pas revendiquer

Le dépôt ne contient pas le jeu initial annoncé de 10 000 requêtes ni de preuve du F1 0,988, des faux positifs 0,5 %, des faux négatifs 0,1 %, des 98 % sous 100 ms, ni des essais SQLmap/Burp/Apache Benchmark annoncés dans les anciens PDF. Les performances sous charge et la latence p50/p95 restent à mesurer.

Sources des calculs : `ia/models/training\_report.json`, `external\_evaluation.json`, `honeypot\_evaluation.json`; données HttpParamsDataset sous licence MIT incluse; capture SR-BH 2020 CC0 1.0. Méthodes et limites détaillées dans `ia/README.md`.

DÉFENSE EN PROFONDEUR

Les garde-fous font partie du produit.

Contrôles documentés

- Requêtes préparées dans les accès de la boutique de démonstration.
- CSRF sur les actions applicatives.
- MFA TOTP pour les comptes d'administration.
- Limites de longueur, de débit et de tentatives d'authentification.
- Filtrage des valeurs sensibles avant analyse et journalisation expurgée.
- Console locale protégée; services internes isolés dans Compose.
- Service IA local et limitations de débit indépendantes.
- Mode monitor pour inspecter avant tout changement de politique.

Risques à maîtriser

- Le classifieur peut laisser passer des attaques ou signaler des entrées légitimes.
- Une panne du service IA peut refuser certains cas ambigus selon la politique active.
- Les journaux incluent des métadonnées de sécurité et doivent être protégés.
- Un modèle ou une dépendance doit provenir d'une source de confiance et être versionné.
- La couverture SQLi ne sécurise pas XSS, CSRF, LFI ou la configuration serveur.
- Les résultats de benchmarks publics ne certifient aucune installation.

Position de sécurité

CyberShield AI complète les requêtes préparées et les contrôles de l'application. Les requêtes préparées restent une protection centrale contre SQLi; le middleware ne prouve jamais qu'une entrée est sûre.

État des évaluations

Évaluation	État	Étape prévue
Tests automatisés du dépôt	99 contrôles sécurité, 42 contrôles applicatifs, 7 contrôles d'accès, 16 tests du modèle et 11 tests pilote/SIEM réussis.	Rejouer les suites sur la révision finale et conserver les sorties avec le dossier.
Pilote chez un client	Non réalisé ou non documenté.	Obtenir l'accord du propriétaire et tester d'abord une copie en observation.
Audit ou test d'intrusion indépendant	Non réalisé ou non documenté.	Mandater un évaluateur sur un environnement isolé explicitement autorisé.
Performance et conteneurs	Pas de p50/p95 ou de test de charge fiable. Compose est syntaxiquement valide; le moteur Docker n'était pas accessible pour confirmer construction et démarrage dans cette session.	Mesurer sur le matériel et les routes du pilote avec un protocole partagé; vérifier les images sur l'hôte Docker.

Une liste de tests automatisés n'est pas équivalente à un audit indépendant. `SECURITE\_ET\_MODELE\_DE\_MENACE.md` décrit le périmètre, les risques résiduels et la demande d'évaluation externe.

POSITIONNEMENT À VÉRIFIER

Une proposition testable, sans nouveauté proclamée.

La différenciation envisagée est une combinaison de traitement local PHP, règles déterministes, analyse MLP bornée et revue d'événements expurgés en mode observation. Sa supériorité face aux options existantes n'a pas encore été mesurée; le pilote et les entretiens doivent établir si cette combinaison résout un problème prioritaire.

Option	Portée documentée	Position de CyberShield AI
Requêtes préparées	Protection côté application contre la construction dangereuse des requêtes SQL; contrôle fondamental à conserver.	Complément de visibilité. Le filtre ne remplace jamais les requêtes paramétrées.
ModSecurity/Coraza avec OWASP CRS	Références WAF établies; OWASP CRS publie des règles SQLi et plusieurs autres familles comme XSS et LFI.	Option plus large à prendre comme référence de comparaison; aucune supériorité face au CRS n'est revendiquée.
CyberShield AI	Middleware local PHP spécialisé SQLi, règles heuristiques, MLP borné, journal et mode observation.	Hypothèse à tester : intégration et revue adaptées à de petites équipes PHP. Aucun avantage de détection ou économique n'est mesuré.

PUBLIC INITIAL ENVISAGÉ

Petites équipes qui maintiennent une application PHP, agences web et intégrateurs locaux. Le besoin, la capacité d'exploitation et la disposition à payer doivent être confirmés par des entretiens.

MISE SUR LE MARCHÉ ENVISAGÉE

Pilote accompagné sur copie de test, installation locale, documentation et support. L'offre récurrente et son prix seront décidés après retours de partenaires; aucun chiffre de marché ou revenu n'est revendiqué.

Objectif des entretiens

Comprendre les pratiques actuelles, les routes où un faux positif serait coûteux, les exigences de confidentialité, l'effort d'intégration et le processus de décision budgétaire.

Références : [OWASP CRS, familles de règles](#); [OWASP SQL Injection Prevention Cheat Sheet](#). La comparaison de performance reste à conduire sur le même banc; détails et protocole dans la grille de candidature.

DE LA DÉMONSTRATION AU TERRAIN

La prochaine preuve est un pilote autorisé.

01 Avant soumission

Réconcilier définitivement les PDF, confirmer les noms et rôles, répéter la démonstration locale et vérifier la date de clôture directement auprès de l'AMRTP.

02 Pilote limité

Obtenir une autorisation écrite, choisir une copie représentative, garder le mode observation, établir une référence de performance et faire étiqueter un échantillon à l'aveugle avec preuve indépendante.

03 Évaluation externe

Faire examiner l'authentification, les frontières réseau, les secrets, les dépendances, les journaux, les scénarios de panne et la suite SQLi non destructive; corriger et republier les résultats.

04 Consolidation produit

Publier un paquet d'intégration, des mesures de latence p50/p95 sur une machine déclarée, un guide de restauration et des retours d'entretiens client avant d'élargir le périmètre.

Équipe indiquée dans les documents source

Sékou Doucouré, porteur; Adama Nakoun Fané, collaborateur. Le dossier initial mentionne un encadrement scientifique. Chaque rôle et l'accord des personnes doivent être confirmés avant l'envoi.

Demande au concours et aux partenaires

Nous cherchons des retours de praticiens et l'opportunité de conduire une évaluation limitée avec une organisation volontaire, ainsi qu'un regard externe sur la robustesse et les faux positifs du prototype.

Décision proposée au jury

Soutenir une expérimentation locale et encadrée qui transforme un démonstrateur académique en produit mesurable, avec ses limites affichées et un protocole de validation transparent.

Références principales : documentation technique et rapports de tests du dépôt; HttpParamsDataset, licence MIT incluse; SR-BH 2020, CC0 1.0, DOI 10.7910/DVN/OGOIXX; [OWASP SQL Injection Prevention Cheat Sheet](#); [Concours Innovation JNC](#); [Programme JNC 2026](#).